



ALMA MATER STUDIORUM  
UNIVERSITÀ DI BOLOGNA

Laboratorio di  
**Sicurezza Informatica**

# **Rischi, attacchi e difese**

**Marco Prandini**

Dipartimento di Informatica – Scienza e Ingegneria

# Il rischio cyber

- Affrontare i problemi di sicurezza informatica è sostanzialmente un esercizio di *gestione del rischio*  
"il potenziale danno immateriale, perdita economica, o distruzione di risorse che risulterebbe da un evento (malevolo)"
- Semplificando in modo estremo:  
**RISCHIO = PROBABILITÀ x IMPATTO**  
es. se nell'arco di un anno c'è una probabilità del 4% di subire un danno di 15.000€ dovuto a un'azione malevola, il rischio è pari a 600€/anno
- Per gestire il rischio dobbiamo conoscerlo
  - valutare le probabilità di ogni evento potenzialmente dannoso
  - quantificare l'impatto di ogni possibile azione malevola
- Per mitigare il rischio si progettano e implementano contromisure (che devono essere convenienti!)
  - bisogna saperne valutare l'efficacia, in termini di riduzione della probabilità degli eventi dannosi e/o del loro impatto

# Detto così sembra facile...

“Progress just means bad things happen faster.”

– Terry Pratchett (from *Witches Abroad*)



“If you think technology can solve your security problems, then you don't understand the problems and you don't understand the technology.”

– Bruce Schneier

# Detto così sembra facile...

“Progress just means bad things happen faster.”

– Terry Pratchett (from *Witches Abroad*)

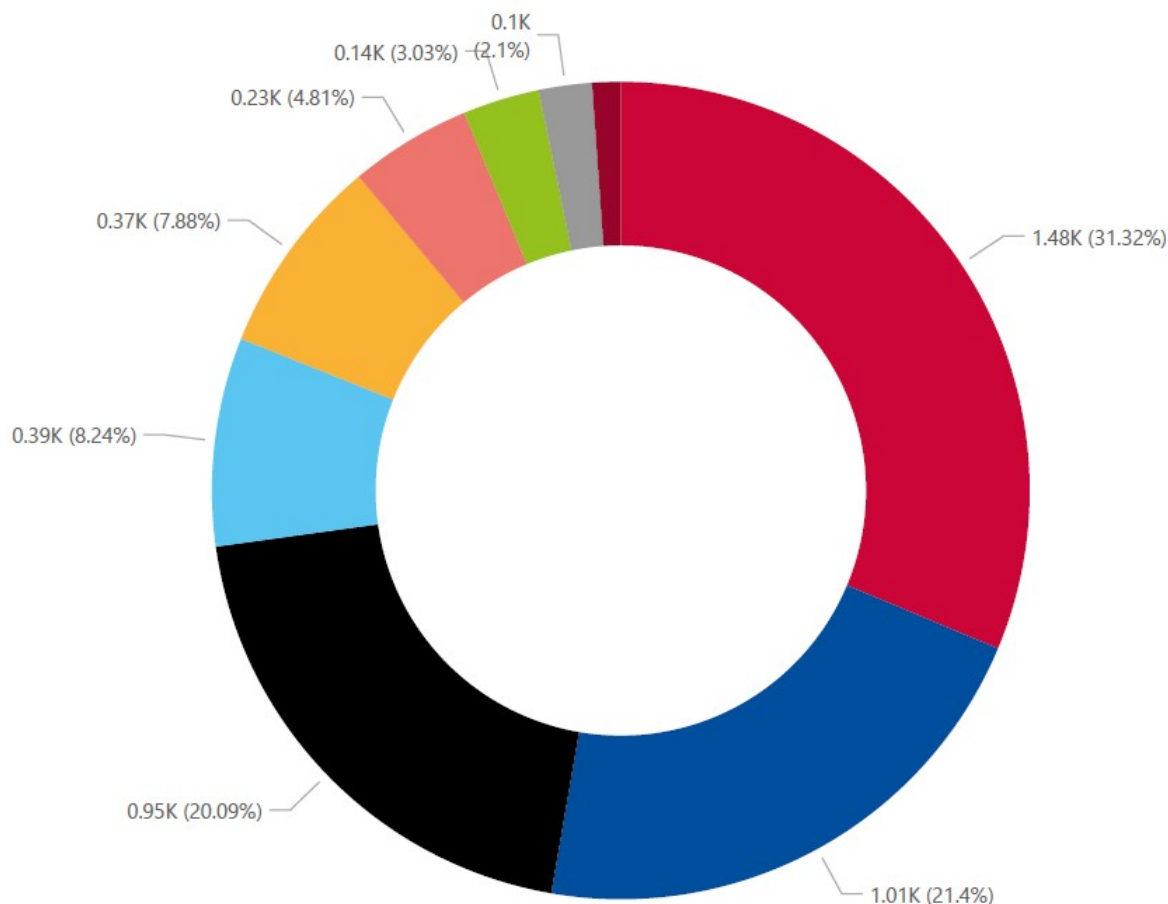
**QUALCUNO HA DETTO LLM?**



“If you think technology can solve your security problems, then you don't understand the problems and you don't understand the technology.”

– Bruce Schneier

# Il panorama delle minacce

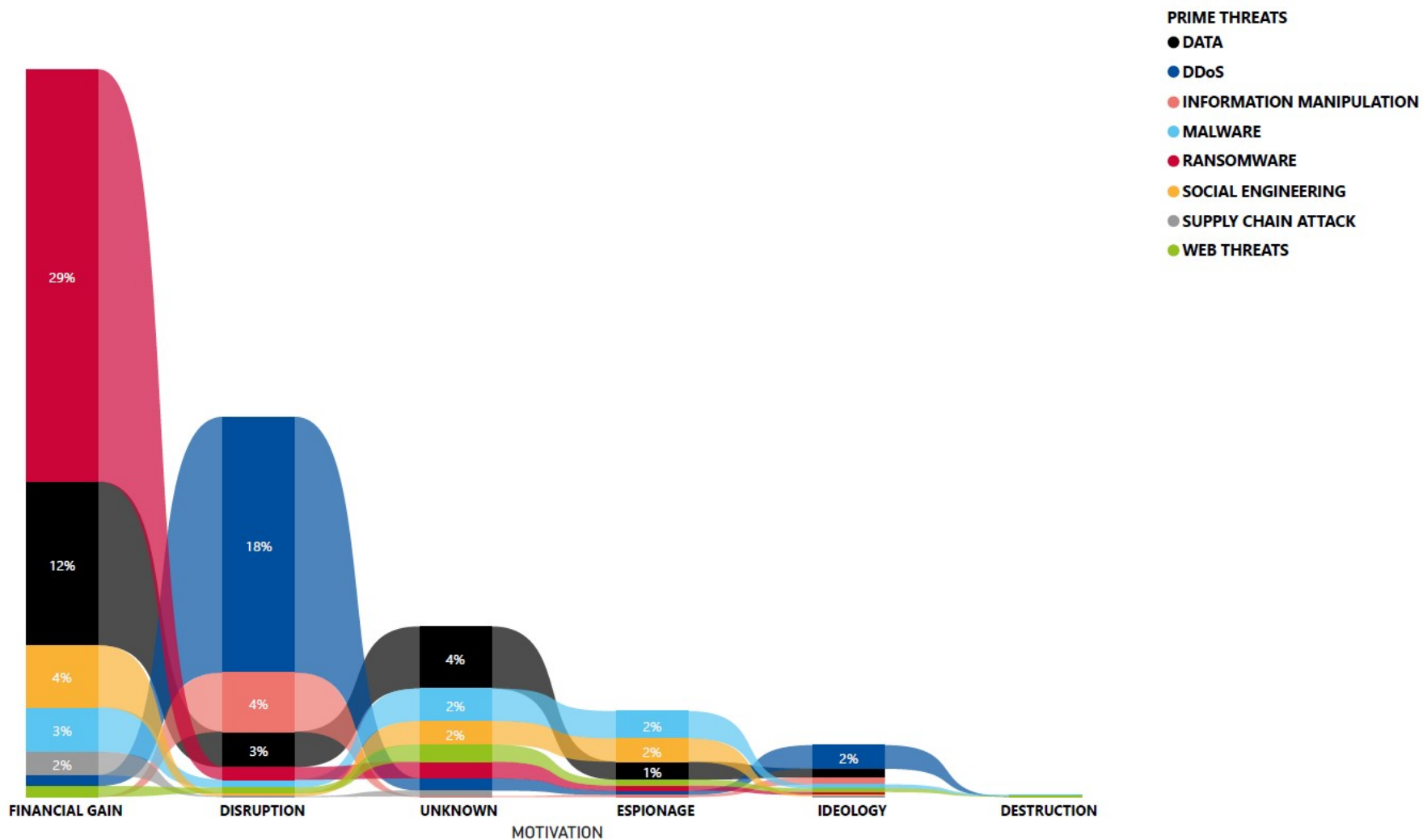


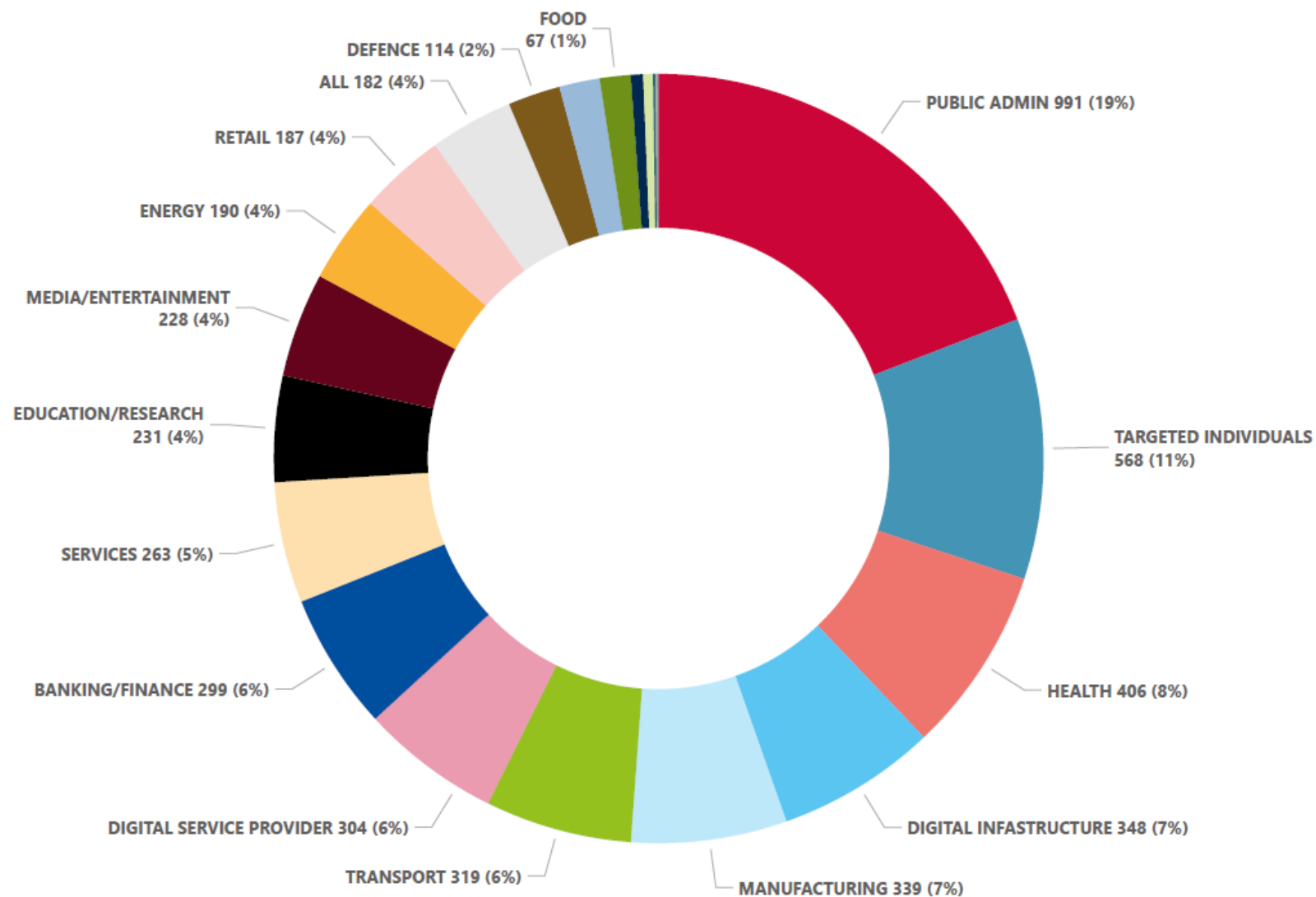
## PRIME THREATS

- RANSOMWARE
- DDoS
- DATA
- MALWARE
- SOCIAL ENGINEERING
- INFORMATION MANIPULATION
- WEB THREATS
- SUPPLY CHAIN ATTACK
- ZERO DAY

<https://www.enisa.europa.eu/publications/enisa-threat-landscape-2023>

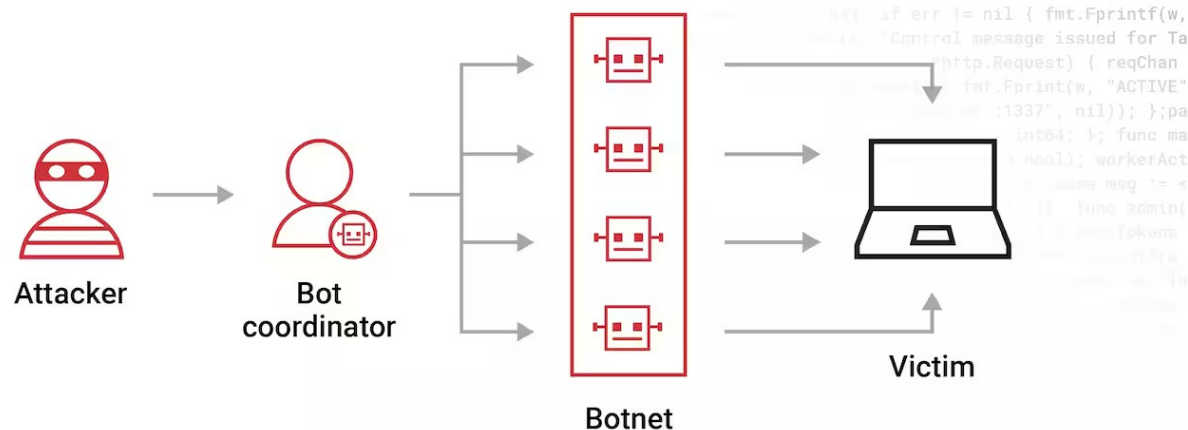
# Le motivazioni





# Esempi di attacchi: Interruzione del Servizio

- Lo scopo è violare la “A” della triade
- Non servono strumenti sofisticati per rubare dati o alterare programmi, spesso solo forza bruta per causare un volume di traffico o di carico di calcolo insostenibile per la vittima
  - > Denial of Service (DoS)
- Spesso per farlo ci si avvale di un'armata di computer in sè di poco valore, ma facili da compromettere, e in numero tale da creare una grande forza d'urto
  - > Di:



# Esempi di attacchi: furti di identità

- Qualcuno ruba le tue informazioni personali (ad esempio il codice fiscale) e lo utilizza senza la tua autorizzazione per creare nuovi account, fare acquisti o commettere altre frodi

## US hacker charged with stealing 130m credit card IDs

The New York Times | <http://ny5.ms/1URDzOm>

TECHNOLOGY | NYT NOW

### Russian Hackers Amass Over a Billion Internet Passwords

By NICOLE PERLOTH and DAVID GELLES AUG. 5, 2014

A Russian crime ring has amassed the largest known collection of stolen Internet credentials, including 1.2 billion user name and password combinations and more than 500 million email addresses, security researchers say.

The records, discovered by Hold Security, a firm in Milwaukee, include confidential material gathered from 420,000 websites, including household names, and small Internet sites. Hold Security has a history of uncovering significant hacks, including the theft last year of tens of millions of records from Adobe Systems.

BUSINESS

## Yahoo says 1 billion user accounts were hacked

### Breaking In

The breach disclosed by Equifax ranks among the largest ever publicly disclosed by a company.

Selected data breaches by number of: ■ Accounts/cards ■ Customers

| COMPANY                | SIZE OF BREACH | YEAR |
|------------------------|----------------|------|
| Yahoo*                 | 1 billion      | 2016 |
| Yahoo*                 | 500 million    | 2016 |
| Equifax                | 143            | 2017 |
| Heartland Payment Sys. | 130            | 2009 |
| LinkedIn               | 117            | 2016 |
| Sony                   | 100            | 2011 |
| TJX                    | 90             | 2007 |
| Anthem                 | 80             | 2015 |
| J.P. Morgan            | 76†            | 2014 |
| Target                 | 70‡            | 2013 |
| Home Depot             | 56             | 2014 |

\*Believed to be separate incidents †Millions of households ‡Initial disclosure

Source: the companies

THE WALL STREET JOURNAL.

# Esempi di attacchi: phishing

- E-mail, messaggi di testo, telefonate o siti Web fraudolenti progettati per indurre gli utenti a scaricare **malware**, condividere informazioni sensibili o dati personali o intraprendere altre azioni che espongono se stessi o le proprie organizzazioni alla criminalità informatica
- Il phishing è la seconda causa più comune di violazione dei dati, e costa alle vittime in media 4,91 milioni di dollari
- Google trova 300.000 nuovi siti di phishing al mese, e molti di essi sono online solo per meno di un'ora

# Esempi di attacchi: phishing



# Esempi di attacchi: phishing

**From:** [redacted] <[redacted]@MSVU.CA>

**Sent:** Friday, September 16, 2022 5:22 PM

**Subject:** We received a request from you

Our record indicates that you recently made a request to terminate your Office 365 email and this process has begun by our administrator. If this request was made accidentally and you have no knowledge of it, you are advised to verify your account below [CLICK HERE](#) To verify. Please give us 24 hours to terminate your account OR verify your account. Failure to Verify will result in closure of your account.

<http://offfc4503032.sitebuilder.name.tools/>  
Click or tap to follow link.

Don't trust an email just because it's from @msvu.ca

IT&S never asks you to click links to verify your account

Watch for spelling, punctuation and grammar errors (highlighted)

The link goes to a suspicious website

# Esempi di attacchi: ransomware

- Crittografare i dati critici di un utente o di un'organizzazione, impedendo l'accesso ai file, database, o applicazioni. L'aggressore richiede il pagamento di un riscatto per decifrarli

## What is WannaCry ransomware and why is it attacking global computers?

Malicious software has attacked Britain's health service and companies in Spain, Russia, the Ukraine and Taiwan. What is it and how is it holding data to ransom?

*Another Hacked Florida City Pays a Ransom, This Time for \$460,000*

## The Extortion Economy: How Insurance Companies Are Fueling a Rise in Ransomware Attacks

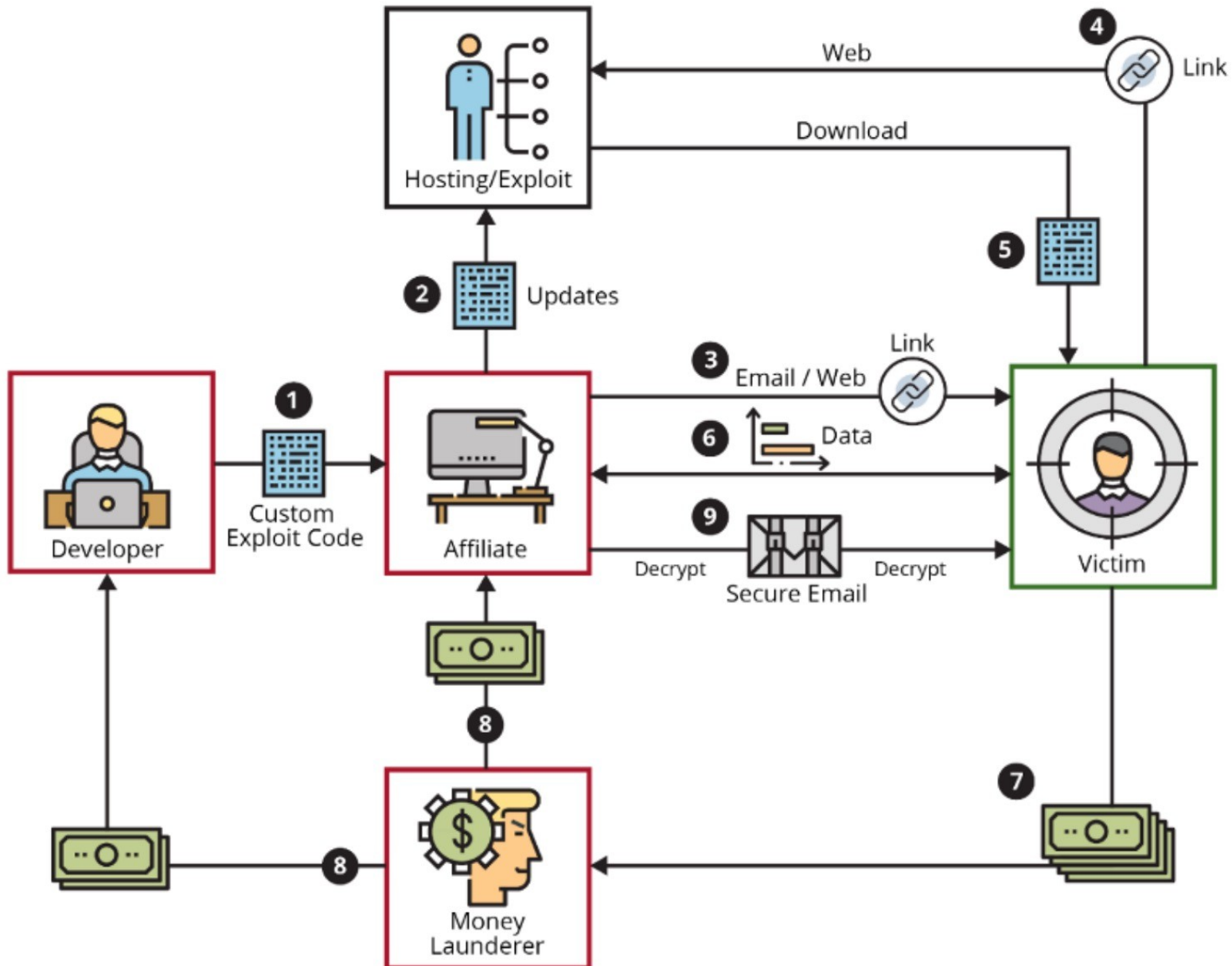
Even when public agencies and companies hit by ransomware could recover their files on their own, insurers prefer to pay the ransom. Why? The attacks are good for business.



# Esempi di attacchi: Ransomware as a Service

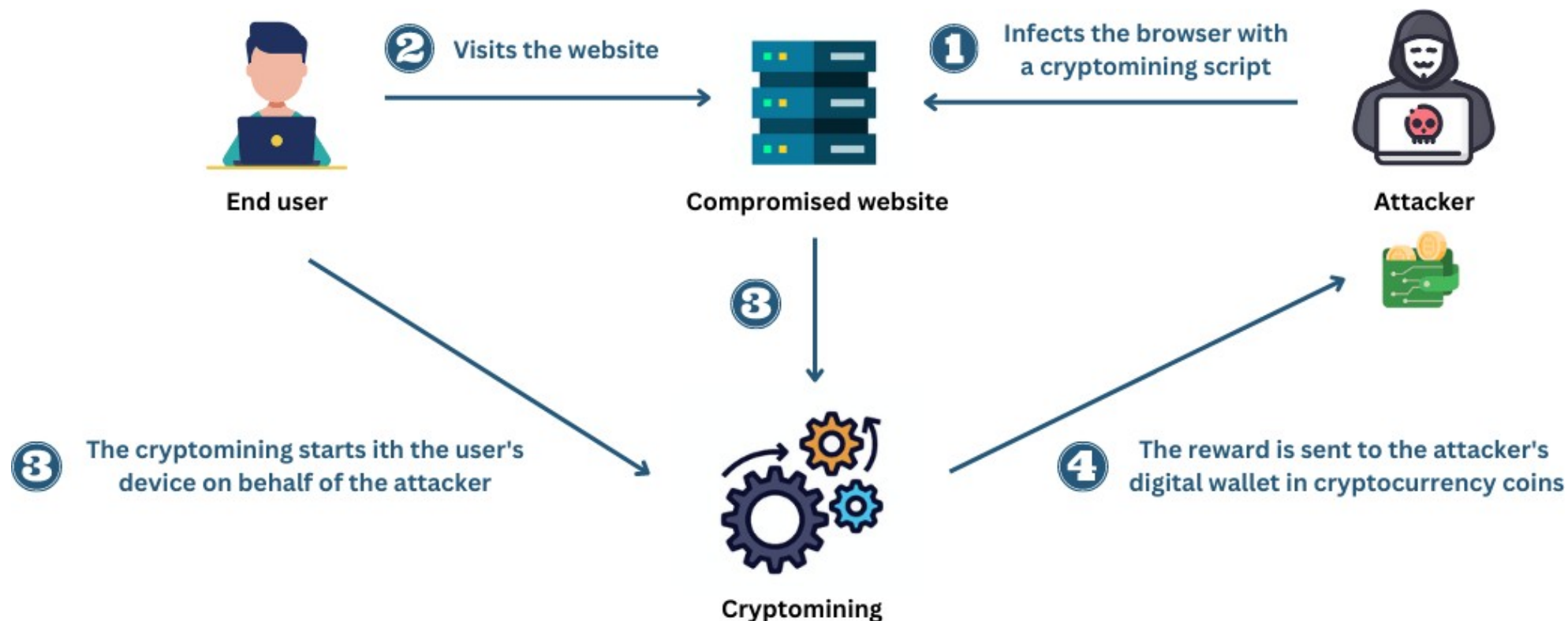
- Nel ransomware come servizio, come DarkSide, uno sviluppatore di malware addebita una tariffa utente agli affiliati, che potrebbero non avere le competenze tecniche per creare un ransomware ma sono in grado di penetrare in un sistema informatico della vittima
- Questi servizi includono il supporto tecnico per i cracker, inclusa la negoziazione con le vittime e la conduzione di campagne di pressione su misura
- Le tariffe per gli utenti di DarkSide variavano a seconda dell'impatto: 25% per riscatti inferiori a 500.000 dollari, con sconti progressivi, fino al 10% per riscatti superiori a 5 milioni di dollari

# Esempi di attacchi: Ransomware as a Service



# Esempi di attacchi: crypto-jacking

- Uso non autorizzato dei dispositivi delle persone per estrarre criptovaluta. Funziona incorporando un JavaScript, ogni visitatore esegue solo una piccola parte di mining, ma il totale del tempo di calcolo raccolto può generare vero valore



# Esempi di attacchi: supply chain

- Sfrutta l'estrema interdipendenza del mondo moderno
- Aggredisce un bersaglio intermedio di per sé non interessante, ma che fornisce componenti hardware o software alle vere vittime
- Esempi:
  - Target  
<https://krebsonsecurity.com/2014/02/target-hackers-broke-in-via-hvac-company/>
  - Solarwinds  
<https://www.cybersecurity360.it/nuove-minacce/attacco-agli-usa-nuovi-dettagli-del-breach-solarwinds-e-come-mitigare-i-rischi/>  
<https://www.avantgrade.com/digital-marketing/attacco-hacker-solarwinds>

# Esempi di attacchi: alla vecchia maniera

- Il furto di un dispositivo fisico resta uno strumento valido anche nel mondo digitale e iperconnesso
  - salta le difese predisposte a controllare il traffico di rete
  - salta le protezioni offerte dal sistema operativo dei calcolatori
  - può causare immediata perdita di Confidenzialità e Disponibilità
- Anche la brutale distruzione...
  - di nuovo minaccia la Disponibilità
- Al giorno d'oggi un elemento è particolarmente a rischio: ovviamente lo **smartphone**
  - contiene dati di immediato valore
  - rappresenta il punto privilegiato per regolare l'accesso a tutti i dati e i servizi esterni utilizzati dal proprietario (si pensi alle app di autenticazione, ai servizi che mandano SMS di conferma, ecc.)

# Quanti incidenti: qualche mese del 2020

| Data breaches                                                                                |   | Ransomware                                                                                                                     |   | Sabot/Espion                                                                                                                            |   | Cyberwar                                                          |
|----------------------------------------------------------------------------------------------|---|--------------------------------------------------------------------------------------------------------------------------------|---|-----------------------------------------------------------------------------------------------------------------------------------------|---|-------------------------------------------------------------------|
| Mitsubishi (employees, projects)<br>CheckPeople (56M US citizens)<br>Wawa (30M credit cards) | J | Travelex (6M\$)<br>US def. contr. CPI (500k\$ -<br>2 months to recover)                                                        | J |                                                                                                                                         | J | 7 events (IR,TK,RU,IL)                                            |
| Clearview AI<br>3bn photos+customer list<br>(law enforcement)                                | F | UK Redcar Council (10M£)                                                                                                       | F | IR DDoS of internet infrastr.                                                                                                           | F | 4 events (RU,CN)                                                  |
| Tetrad (747GB data on households)<br>Virgin Media (900k users)<br>US Census (200M citizens)  | M | UK Durham fire/police/govt.svcs                                                                                                | M | SA exploit global telco bug to<br>track citizens<br>CN espionage on 75 org. ww.                                                         | M | 3 mass surveillance (KP,KR,UZ)<br>2 wide industry attacks (CN,US) |
| Nintendo (160k accounts)<br>Zoom (500k accounts)                                             | A | Energias de Portugal (9.9M€)                                                                                                   | A | AZ SCADA wind turbines                                                                                                                  | A | 9 events (VN,RU,CN,IR)                                            |
| EasyJet (9M records)<br>CAM4 adult live (10M+ users)                                         | M | 21 incidents reported, including<br>Fresenius hospital operator &<br>NYC law firm representing celebs                          | M | JP/IT/DE/UK industrial suppliers<br>RU→DE spl.ch.→energy/water<br>NO state fund empl. tricked 10M\$                                     | M | 11 events (RU,CN,IR,IL)                                           |
|                                                                                              | J | UC Covid-19 research data (1.14M\$)<br>Most Honda offices shut down<br>(Enel blocked a similar attack)                         | J | Backdoor found in mandatory<br>tax-filing software for foreign<br>companies operating in China                                          | J | 8 events (KP,CN,IN)                                               |
|                                                                                              | J | Telecom Argentina (7.5M\$)<br>Garmin (3 days down)                                                                             | J |                                                                                                                                         | J | 5 events (RU,CN,US)                                               |
| 235M Instagram, TikTok and<br>YouTube user profiles<br>Carnival customers & employees        | A | NL CWT travel (4.5M\$)<br>Konica Minolta (1 week down)                                                                         | A | IL water infrastructure<br>NZ Stock Exchange DdoS<br>KP worldwide ATM robbery<br>IR→US mf backdoor injection<br>CN→TW code&design theft | A | 9 events (KP,IR,RU,CN,IN)                                         |
| SK Covid tracing (390k patients)                                                             | S | 31 incidents, including<br>(DE) Duesseldorf University H.<br>(AG) Dir. Nac. Migraciones (4M\$)<br>(PK) electric company (4M\$) | S | Georgia COVID research espion.                                                                                                          | S | 9 events (IR,CN,RU)                                               |
| Marriott fined 18M£ for<br>2014-2018 leak of 339M customer<br>data                           | O | 40 incidents, including<br>ERT (disrupted vaccine tests)<br>DE Software AG (20M\$)                                             | O |                                                                                                                                         | O | 24 events (IR,CN,RU,GR,KP)                                        |

# L'effetto COVID

- Lockdown =
  - Telelavoro → maggiore utilizzo di dispositivi e reti non gestiti
  - Incremento dell'uso dei servizi online personali → e-commerce, e-banking, social network, più usati da utenti esperti e più nuovi utenti non consapevoli dei rischi
- *Coronavirus is alone blamed for a 238% rise in cyber attacks on banks.*
- *Phishing attacks have seen a dramatic increase of 600% since the end of February.*
- *Ransomware attacks rose 148% in March and the average ransomware payment rose by 33% to \$111,605 as compared to Q4 2019.*

*(Source: Fintech News)*

- I maggiori incidenti del 2021 riassunti <https://securityinsight.nl/report/check-point-2022-cyber-security-report>

# Quanti incidenti: 2022 in sintesi

## ■ January

- Ukraine has been hit by a large scale cyber-attack that took down several of its government and ministries websites
- In Iran, television channels and radio stations were hacked by an exiled opposition group

## ■ February

- A ransomware disrupted operations of oil port terminals in Belgium, Germany, and Netherlands
- Ukraine has been at the centre of a series of DDoS attacks on its armed forces, defence ministry, public radio, and national banks
- Hackers leveraged an announce of OpenSea to scam NFT users and steal millions of dollars

## ■ March

- Ukraine has claimed attacks taking down multiple Russian and Belarusian key websites, including that of the Kremlin
- A ransomware gang stole 2 code signing certificates used by NVIDIA to sign their drivers and executables
- One of the largest Russian meat producers had their IT systems encrypted, resulting in distribution disruptions for several days

## ■ April

- A set of vulnerabilities in the ALAC audio format that could have been used for remote code execution on two-thirds of the world's mobile devices
- Vulnerability in Everscale blockchain wallet, giving an attacker full control of victim's funds

## ■ May

- Costa Rica has been victim of a ransomware attack, resulting in the loss of \$200 million
- A ransomware occurred in December 2021 lead to the closing of the Lincoln College, a 157-year-old institution of Illinois
- A Russian banking services organization experienced the largest DDoS attack ever recorded (450 GB/sec)

## ■ June

- The largest ever-recorded HTTPS DDoS attack targeting Cloudflare customers has been mitigated
- Russia has increased attacks against governments and NGOs supporting Ukraine

## ■ July

- Norway and Lithuania were victims of a large-scale DDoS
- Twitter has suffered a data breach affecting 5.4 million accounts

## ■ August

- Cisco has been breached by a ransomware group
- DDoS attack targeting Lockheed Martin
- The largest water company supply of the UK has been victim of a ransomware, causing the disruption of the company's IT system and allowing them to access more than 5TB of data
- A cryptocurrency mining campaign imitating Google Translate Desktop

## ■ September

- A traffic jam attack to hack the Russian taxi service Yandex
- Iran has performed multiple cyberattacks to disrupt Albania's government systems
- Uber has suffered a data breach

## ■ October

- Hacktivist groups have been leaking information on Iranian government officials and offering support in sharing information
- Personal information of 10 million Australians has been stolen
- Russian attacks tacking down different US and Bulgarian state government websites
- The largest copper manufacturer has been victim of a cyberattack that shut down many of its IT systems

## ■ November

- Ukraine IT Army leaked 27K files from the Russia's Central Bank
- The Azov ransomware has being distributed worldwide
- Meta employees granted access to user's Facebook and Instagram profiles in return of thousands of dollars in bribes
- The European Parliament website has been hacked following a vote declaring Russia a state sponsor of terrorism
- A ransomware group has been running a campaign targeting USA, Canada, United Kingdom, Australia, and New Zeland

## ■ December

- Release of a batch of data from Australian Medibank's system
- 300,00 users across 71 countries were affected by an Android campaign to steal Facebook credentials

# Fast forward, qualche attacco cyber notevole

## ■ Riassunto di chatGPT a ottobre 2025

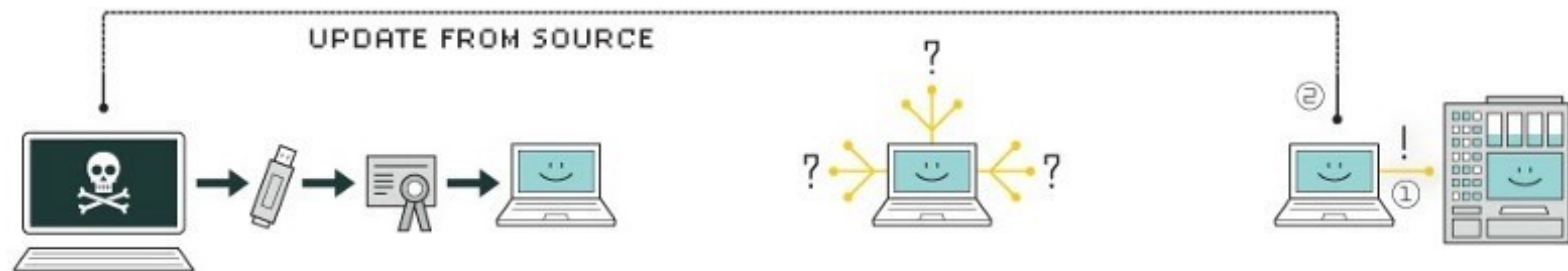
|                                               |                                                                                                                                                    |                                                                               |
|-----------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------|
| July 30 2025 – Detroit, U.S.                  | Breach in Great Lakes Water Authority's monitoring system; operations unaffected but under investigation.                                          | Potential risk to safe water operations.                                      |
| April 2025 – Bremanger dam, Norway            | Hackers allegedly gained control of a dam's flood-gates and released ~500 litres per second of water for ~4 hours before the incident was stopped. | Cyber-sabotage of water infrastructure; no injuries but physical damage risk. |
| December 2024 – Water utility plant, Denmark  | Destructive cyber-attack hit Danish water utility plant; limited damage reported.                                                                  | Demonstrates destructive intrusion into water infrastructure.                 |
| August 2024 – Halliburton, energy sector      | Unauthorized access discovered in Halliburton's systems.                                                                                           | Potential impact on industrial energy systems.                                |
| January 2024 – Lviv heating utility, Ukraine  | Malware (FrostyGoop) disabled heat/hot-water to ~600 buildings for ~48 hours.                                                                      | Potential harm to people due to lack of heating.                              |
| Late 2023–2024 – U.S. critical infrastructure | Cyber-actors gained access to industrial control systems in water/wastewater, food/agri sectors in the U.S.                                        | Potential physical harm through compromised control systems.                  |

# Esempi di incidenti: guerra cyber

- Nel 2009, il segretario alla Difesa americano Robert Gates ha dichiarato che il cyberspazio è “quinto dominio” delle operazioni militari, accanto a terra, mare, aria e spazio
- Gli Stati Uniti attualmente schierano 6.200 cyber-soldati
- Il cyber è diventato l’arma preferita da molti paesi come North Corea, Russia, Cina e Iran per rubare, interrompere servizi, e minacciare
- New York Times, 26 July 2016
  - *“Spy agency consensus grows that Russia hacked D.N.C.”* American intelligence agencies have told the White House they now have “high confidence” that the Russian government was behind the theft of emails and documents from the Democratic National Committee
- The Washington Post, 22 September 2017
  - *“DHS tells states about Russian hacking during 2016 election”* The Department of Homeland Security contacted election officials in 21 states Friday to notify them that they had been targeted by Russian government hackers during the 2016 election campaign

# Esempi di incidenti: guerra cyber

## HOW STUXNET WORKED



### 1. infection

Stuxnet enters a system via a USB stick and proceeds to infect all machines running Microsoft Windows. By brandishing a digital certificate that seems to show that it comes from a reliable company, the worm is able to evade automated-detection systems.

### 2. search

Stuxnet then checks whether a given machine is part of the targeted industrial control system made by Siemens. Such systems are deployed in Iran to run high-speed centrifuges that help to enrich nuclear fuel.

### 3. update

If the system isn't a target, Stuxnet does nothing; if it is, the worm attempts to access the Internet and download a more recent version of itself.



### 4. compromise

The worm then compromises the target system's logic controllers, exploiting "zero day" vulnerabilities—software weaknesses that haven't been identified by security experts.

### 5. control

In the beginning, Stuxnet spies on the operations of the targeted system. Then it uses the information it has gathered to take control of the centrifuges, making them spin themselves to failure.

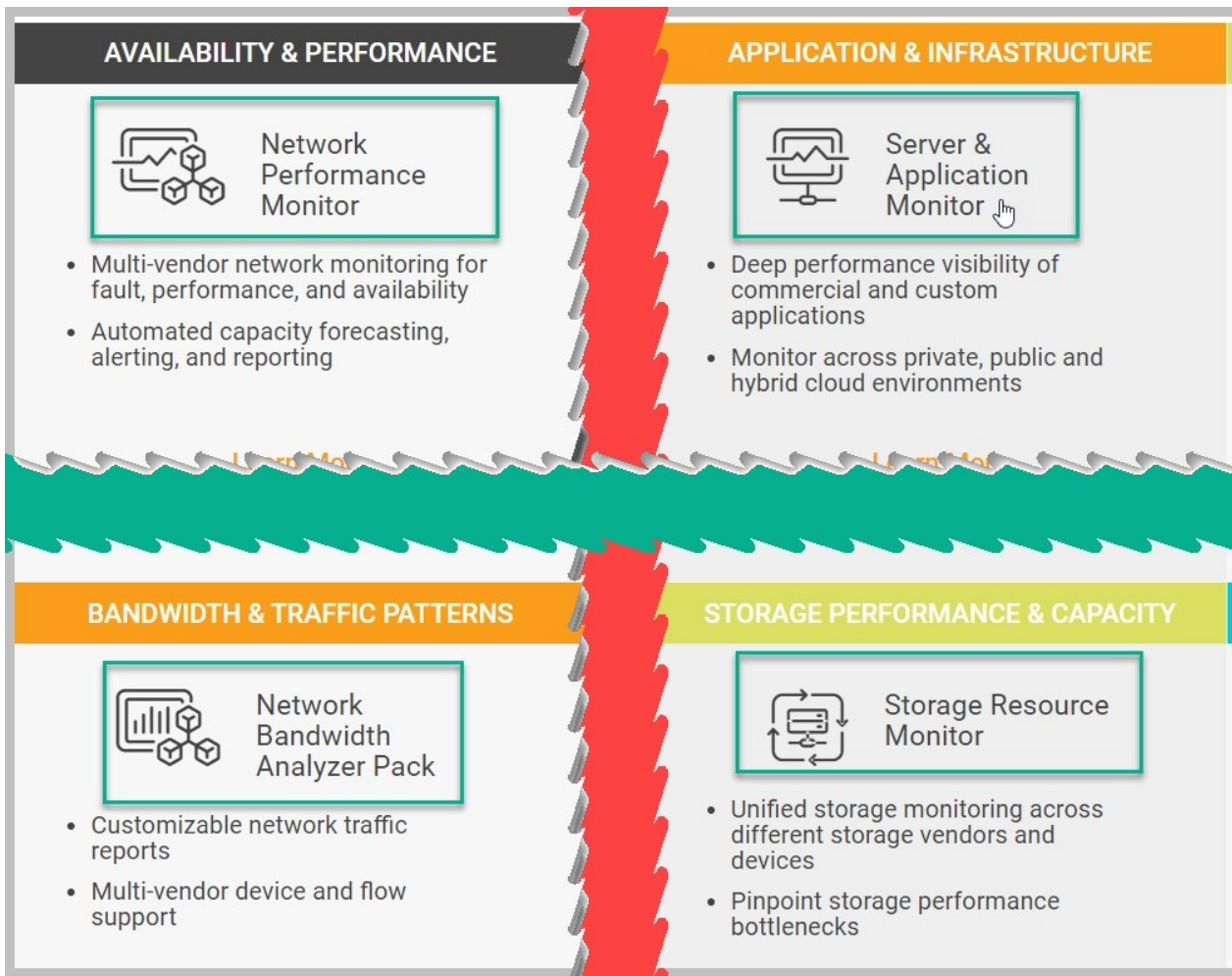
### 6. deceive and destroy

Meanwhile, it provides false feedback to outside controllers, ensuring that they won't know what's going wrong until it's too late to do anything about it.

# Esempi di incidenti: Solarwinds

## ■ Solarwinds fornisce servizi a terzi, tra cui

- l'esercito USA;
- il Pentagono;
- il Dipartimento di Stato;
- la NASA (National Aeronautics and Space Administration);
- l'NSA (National Security Agency);
- le poste USPS (United States Postal Service);
- il Ministero di Giustizia;
- l'Ufficio del Presidente USA;
- le principali 5 aziende di accounting.
- ...
- *Telecom Italia*



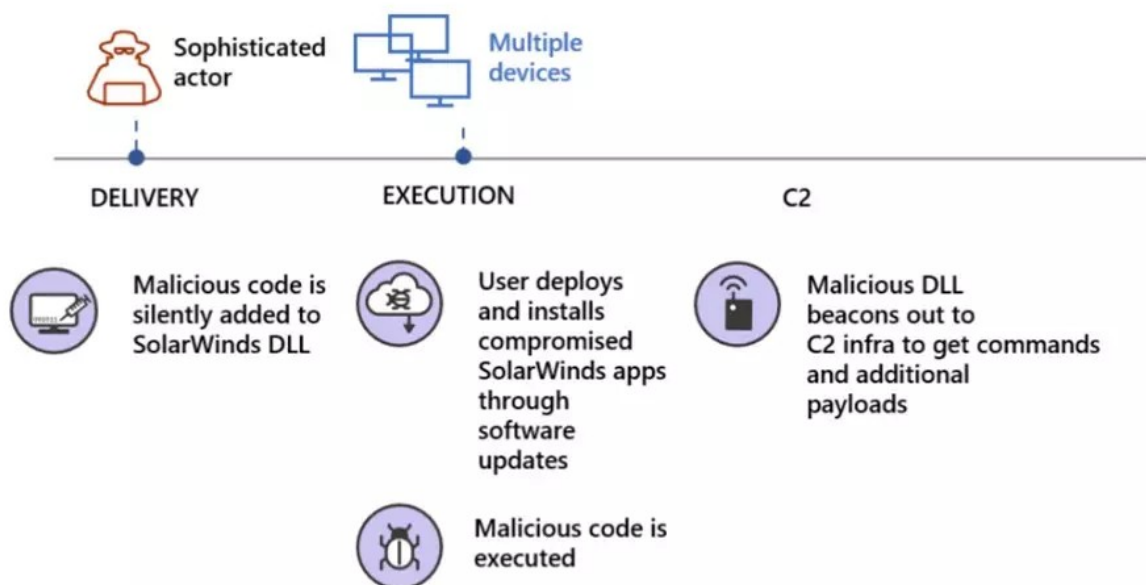
# Esempi di incidenti supply chain: Solarwinds

## ■ Falla nella piattaforma Orion

- accesso senza autenticazione
- visibilità di tutti i dati dei clienti

## ■ Elemento di grande interesse: persistenza

- invece che cercare un modo di restare dentro tutti i sistemi vittima, gli attaccanti hanno trovato un modo di violare il processo di aggiornamento delle librerie, apparentemente innocue, usate da loro



# Esempi di incidenti supply chain: repository

- **ARS Tecnica, 16 February 2021** “New type of supply-chain attack hit Apple, Microsoft and 33 other companies”

*The so-called dependency confusion or namespace confusion attack starts by placing malicious code in an official public repository such as NPM (JavaScript) or PyPI (Python). By giving the submissions the same package name as dependencies used by companies such as **Apple, Microsoft, Tesla, and 33 other companies**, a researcher was able to get these companies to automatically download and install the counterfeit code*

- **Succede anche sugli app store, colpendo normali utenti di smartphone!**

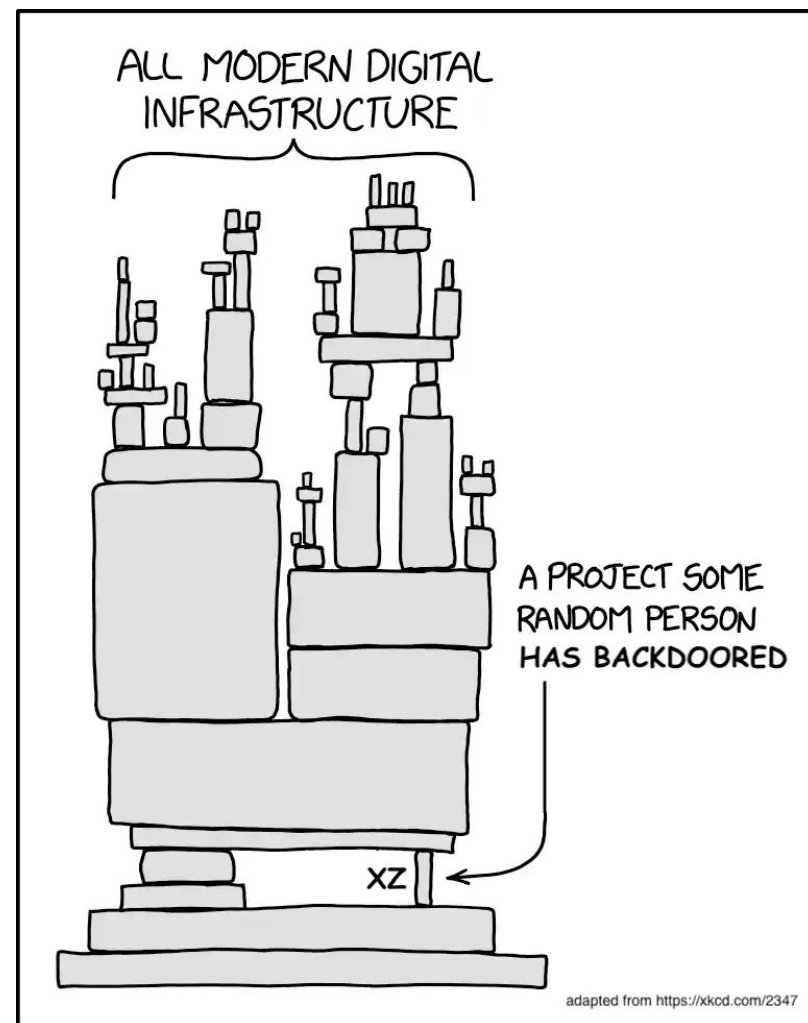
# Esempi di incidenti: open source social eng.

29 marzo 2024: svelata una backdoor nella libreria xz/liblzma, una libreria di algoritmi di compressione largamente utilizzata da comandi e servizi in ambiente Linux (potenziale RCE!)

- <https://www.cve.org/CVERecord?id=CVE-2024-3094>
- <https://nvd.nist.gov/vuln/detail/CVE-2024-3094>

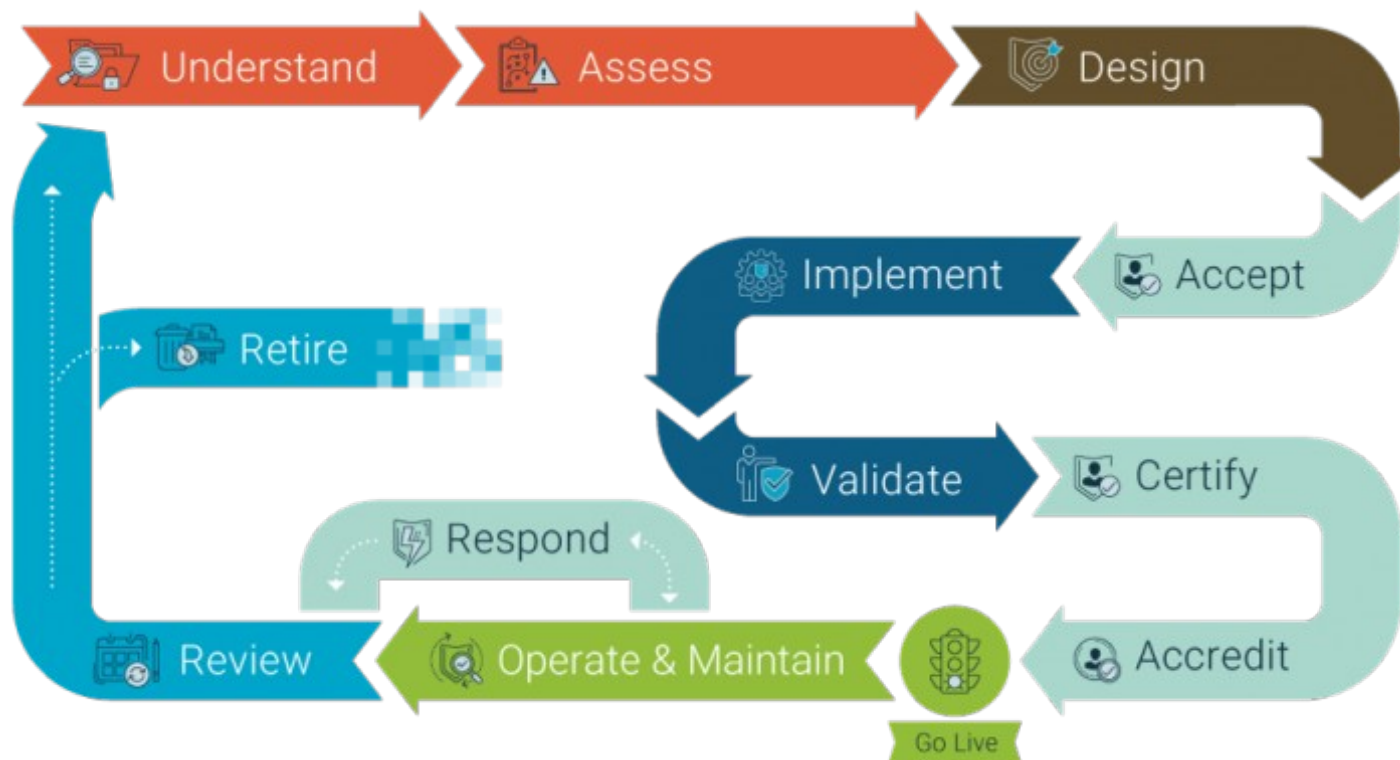
Due aspetti notevoli:

- **Sofisticazione tecnica**  
[https://x.com/fr0gger\\_/status/1774342248437813525](https://x.com/fr0gger_/status/1774342248437813525)
- **Attacco social engineering nel processo di sviluppo**
  - <https://boehs.org/node/everything-i-know-about-the-xz-backdoor>
  - 2021: L'utente *Jia Tan* crea il proprio account GitHub
  - 2022: *Jia Tan* propone una patch, e compare un nuovo utente *Jigar Kumar* che insiste perché venga accettata
  - *Jigar Kumar* comincia anche a insistere perché il mantainer di xz, *Lasse Collin*, si faccia affiancare, facendo leva sui problemi mentali di Collin
  - In qualche modo legato a queste pressioni, *Jia Tan* diventa "affidabile" e comincia a mandare numerosissimi contributi al progetto
  - *Jigar Kumar* scompare nel nulla e compare *Dennis Ens* a fare pressioni per la sostituzione di Collin
  - 2023: *Jia Tan* **sostituisce Lasse Collin** e approva immediatamente un contributo di *Hans Jansen*, un utente fino a quel momento quasi inattivo
  - Insieme *Tan* e *Jansen* fanno pressioni perché la loro versione venga inclusa in Debian
  - 2024: *Tan* sposta il progetto su pagine completamente controllate da lui, e carica il componente finale per attivare la backdoor



# Difesa: Un processo continuo

Sicurezza non è valutare la situazione presente e comprare un **prodotto**, bensì definire un **processo** per tenere traccia delle continue evoluzioni dei rischi e dell'efficacia delle contromisure



# Difesa - metodo

- La messa in sicurezza deve essere un processo metodico
- I *framework* e le *metodologie* possono aiutare nella sistematizzazione
- Le *certificazioni* possono dare evidenza, fornita da una terza parte disinteressata, che misure efficaci siano state adottate da una controparte
  - La sicurezza della supply chain è diventata un elemento cruciale
- Vediamo solo una minuscola panoramica di alcuni elementi importanti



# Politiche e meccanismi

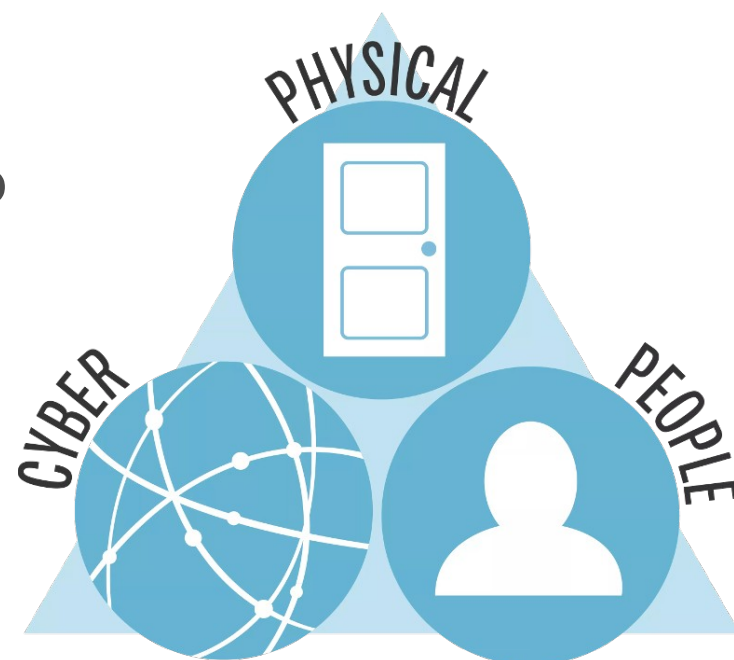
- Una **politica di sicurezza** (*security policy*) è la dichiarazione di ciò che è consentito o proibito fare
- Un **meccanismo di sicurezza** (*security mechanism*) è un metodo, uno strumento o una procedura per far rispettare una politica di sicurezza
- Non sono necessariamente tecnici, anzi molto spesso, tra i più importanti, ci sono comportamenti e regole di interazione tra persone

# Obiettivi delle politiche e dei meccanismi

- Le politiche dichiarano qual è il fine della sicurezza
- I meccanismi specificano il mezzo per contrastare gli attacchi, e possono combinare diverse strategie:
  - **Prevenzione (*prevention*)**: l'attacco deve fallire
    - Meccanismi invasivi
    - Implementazione inalterabile e non aggirabile
  - **Rilevazione (*detection*)**: l'attacco potrebbe avere successo ma deve essere notato e riportato
    - Inefficace rispetto ad alcune minacce, es. disclosure
  - **Reazione (*response*)**: l'attacco rilevato viene mitigato per ridurre la gravità o l'estensione del danno
  - **Ripristino (*recovery*)**: le conseguenze dell'attacco vengono ridotte o azzerate, ripristinando le proprietà di sicurezza violate

# Superficie di attacco

- Politiche e meccanismi si applicano a ogni interazione del sistema col mondo esterno (o tra sottosistemi)
- Ogni modo reso accessibile a un attaccante per stimolare un'interazione è un **vettore di attacco**
- Ogni vettore può essere realizzato combinando uno o più canali di accesso
  - Fisico
  - “Cyber” (accesso remoto via cavo o wireless)
  - Umano
- L'insieme dei vettori costituisce la superficie di attacco



# Prevenzione

- Come tutti i processi ingegneristici, politiche e meccanismi derivano da
  - Analisi di requisiti
  - Progetto
  - Implementazione
  - Test
- Devono essere applicati a
  - Processi organizzativi
  - Contesto fisico
  - Sistemi
  - Reti
  - Applicazioni

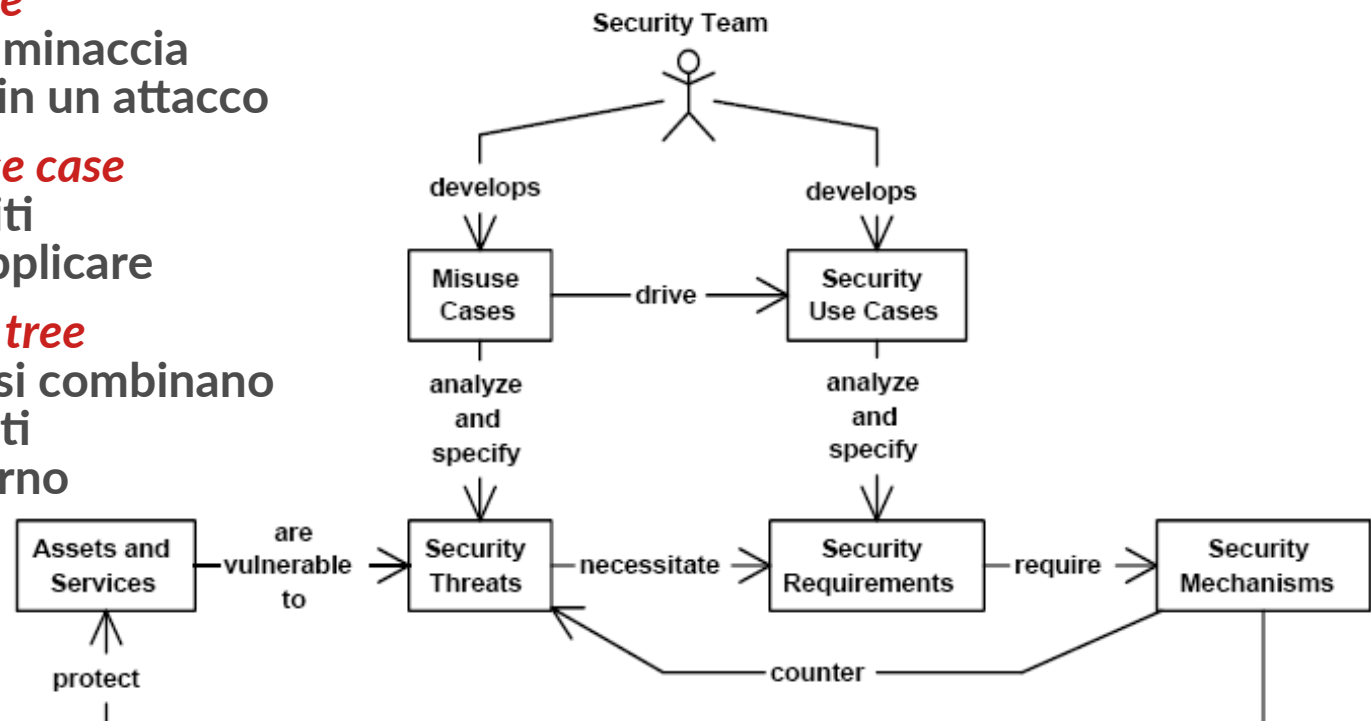
# Prevenzione - Security Engineering

## ■ Prima sfida: non trascurare nemmeno un dettaglio

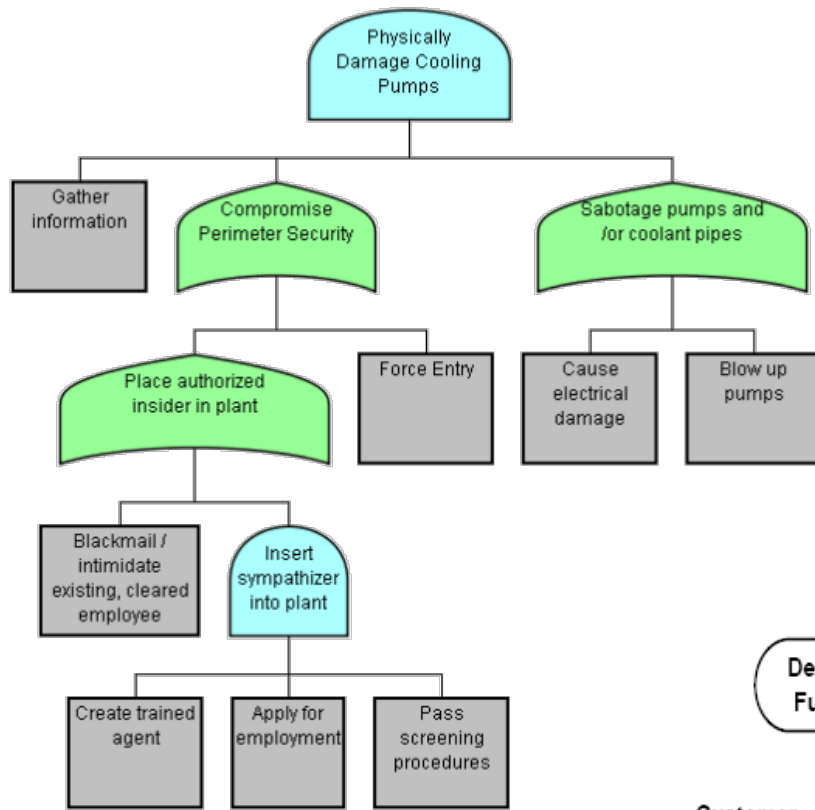
- Inventario di tutti i componenti fisici
- Catalogo di tutti i servizi

## ■ Raccolta dei requisiti

- Molto diversa da quella tradizionale: focalizzata sul “non deve accadere” invece che sul “deve funzionare”
- Studio dei *misuse case* per verificare se una minaccia si può concretizzare in un attacco
- Studio dei *security use case* per distillare i requisiti dei meccanismi da applicare
- Definizione di *attack tree* per modellare come si combinano diversi possibili eventi e condizioni al contorno

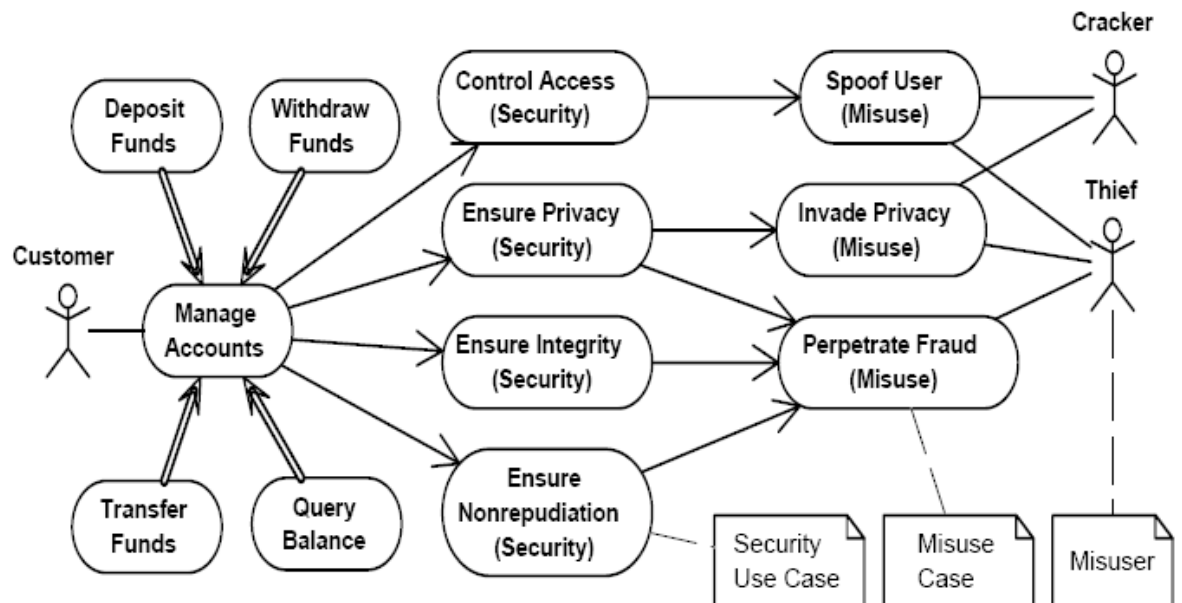


# Security Engineering - esempi



attack tree

## use/misuse cases



# Security Engineering – migliori pratiche

- 1) Basare le decisioni della sicurezza su una esplicita politica
  - a) Identity
  - b) Access control
  - c) Content-specific
  - d) Network and infrastructure
  - e) Regulatory
  - f) Advisor and information
- 2) Evitare un singolo punto di fallimento (defense in depth)
- 3) Fallire in modo certo
- 4) Bilanciare sicurezza e usabilità
- 5) Essere consapevoli dell'esistenza dell'ingegneria sociale
- 6) Usare ridondanza e diversità riduce i rischi
- 7) Validare tutti gli input
- 8) Dividere in compartimenti i beni
- 9) Progettare per il deployment
- 10) Progettare per il ripristino

# Prevenzione - Testing

## ■ Fondamentale per

- verificare se sono sfuggite vulnerabilità
- verificare se il sistema è esposto a rischi nuovi rispetto al momento della progettazione

## ■ Problema concettuale: copertura

- Non si può dimostrare l'assenza di problemi
- Solo tentare di sollecitare il sistema nel modo più completo possibile per trovare eventuali problemi esistenti

## ■ Tre livelli di approfondimento

- Vulnerability Assessment
- Penetration Testing
- Red Team Operations

# Quando testare?

- Prima è meglio



## Shift Left Testing



<https://www.bmc.com/blogs/what-is-shift-left-shift-left-testing-explained/>  
<https://www.xenonstack.com/insights/shift-left-testing>